

ANEXO A

(NORMATIVO)

OBJETIVOS DE CONTROL Y CONTROLES

Los objetivos de control y los controles listados en la tabla A.1 están directamente derivados de y alineados con aquellos listados en los capítulos 5 al 15 de la Norma ISO/IEC 17799:2005. Las listas en la tabla A.1 no son exhaustivas, y una organización puede considerar que son necesarios objetivos de control y controles adicionales. Los objetivos de control y los controles de estas tablas deben seleccionarse como parte del proceso del SGSI especificado en el apartado 4.2.1.

Los capítulos 5 al 15 de la Norma ISO/IEC 17799:2005 proporcionan consejo y orientación, para la implementación de las mejores prácticas en apoyo a los controles especificados en los apartados A.5 hasta A.15.

TABLA A.1: OBJETIVOS DE CONTROL Y CONTROLES

A.5 Política de seguridad		
A.5 Política de seguridad de la información		
<i>Objetivo:</i> Dirigir y dar soporte a la gestión de la seguridad de la información, de acuerdo con los requisitos del negocio, las leyes y reglamentos pertinentes.		
A.5.1.1	Documento de la política de seguridad de la información	<i>Control</i> Un documento de política de seguridad de información será aprobado por la dirección, publicado y comunicado a todos los empleados y partes externas pertinentes.
A.5.1.2	Revisión de la política de seguridad de la información	<i>Control</i> La política de seguridad de la información debe revisarse a intervalos planificados, o si ocurren cambios significativos asegurar su conveniencia, adecuación y eficacia continua.
A.6 Organización de la seguridad de la información		
A.6.1 Organización interna		
<i>Objetivo:</i> Gestionar la seguridad de la información dentro de la organización		
A.6.1.1	Compromiso de la dirección para la seguridad de la información	<i>Control</i> La dirección debe apoyar activamente la seguridad dentro de la organización a través de la dirección clara, del compromiso demostrado, la asignación explícita, y el reconocimiento de las responsabilidades de seguridad de la información.
A.6.1.2	Coordinación de la seguridad de la información	<i>Control</i> Las actividades de seguridad de la información deben coordinarse con representantes de diferentes partes de la organización, con roles y funciones de trabajo pertinentes.
A.6.1.3	Asignación de responsabilidades sobre seguridad de la información	<i>Control</i> Deben definirse claramente todas las responsabilidades de seguridad de la información.
A.6.1.4	Proceso de autorización para los recursos de procesamiento de la información	<i>Control</i> Debe definirse e implementarse un proceso de autorización para cada nuevo recurso de procesamiento de la información.

A.6.1.5	Acuerdos de confidencialidad	Control Debe identificarse y regularmente revisarse los requisitos para los acuerdos de confidencialidad o no divulgación que reflejan las necesidades de la organización, para la protección de la información.
A.6.1.6	Contacto con las autoridades	Control Deben mantenerse los contactos apropiados con las autoridades pertinentes.
A.6.1.7	Contacto con grupos interesados especiales	Control Deben mantenerse los contactos apropiados con grupos interesados especiales u otros foros de especialistas de seguridad y asociaciones profesionales.
A.6.1.8	Revisión independiente de la seguridad de la información	Control El enfoque de la organización para gestionar la seguridad de la información y su implementación (es decir, objetivos de control, controles, políticas, procesos, y procedimientos para la seguridad de la información) deben revisarse de forma independiente, a intervalos planificados, o cuando ocurren cambios significativos en la implementación de la seguridad.
A.6.2 Partes externas		
Objetivo: Mantener la seguridad de la información y recursos de procesamiento de la información de la organización que son accedidos, procesados, comunicados, o gestionados por entidades o partes externas.		
A.6.2.1	Identificación de riesgos relacionados a partes externas	Control Los riesgos a la información y recursos de procesamiento de la información de la organización, para los procesos del negocio que involucran partes externas, deben identificarse y deben implementarse los controles apropiados antes de otorgar el acceso.
A.6.2.2	Tratamiento de la seguridad en las relaciones con clientes	Control Todos los requisitos de seguridad identificados deben tratarse antes de dar el acceso al cliente a la información, o posesiones de la organización.
A.6.2.3	Tratamiento de la seguridad en los acuerdos de terceras partes	Control Los acuerdos con usuarios de terceras partes que involucran acceder, procesar, comunicar o gestionar la información de la organización o los recursos para el tratamiento de la información, o agregar productos o servicios a recursos para el tratamiento de la información, deben cubrir todos los requisitos de seguridad pertinentes.
A.7 Gestión de activos		
A.7.1 Responsabilidad por los activos		
Objetivo: Alcanzar y mantener la protección apropiada de los activos de la organización.		
A.7.1.1	Inventario de activos	Control Todos los activos deben identificarse claramente y elaborarse, y mantenerse el inventario de todos los activos importantes.
A.7.1.2	Propiedad de los activos	Control Toda información y activos asociados con las instalaciones de procesamiento de la información deben ser "dueño" ³ por una parte designada de la organización.

3 Explicación: El término "dueño" identifica a un individuo o entidad que tiene responsabilidad de gestión aprobada para controlar la producción, desarrollo, mantenimiento, utilización y seguridad de los activos. El término "dueño" no significa que la persona actualmente tiene derechos de propiedad sobre el activo.

A.7.1.3	Utilización aceptable de los activos	<i>Control</i> Deben identificarse, documentarse e implementarse las reglas, para la utilización aceptable de la información y los activos asociados con las instalaciones de procesamiento de la información.
A.7.2 Clasificación de la información		
<i>Objetivo:</i> Asegurar que la información reciba un nivel apropiado de protección.		
A.7.2.1	Directrices de clasificación	<i>Control</i> La información debe clasificarse en relación con su valor, requisitos legales, sensibilidad y criticidad para la organización.
A.7.2.2	Etiquetado y manejo de la información	<i>Control</i> Un conjunto apropiado de procedimientos para etiquetar y manejar la información debe desarrollarse e implementarse de acuerdo con el esquema adoptado por la organización.
A.8 Seguridad de recursos humanos		
A.8.1 Antes del empleo⁴		
<i>Objetivo:</i> Asegurar que los empleados, los contratistas y usuarios de terceras partes comprendan sus responsabilidades, y que sean apropiados para los roles considerados, y para reducir el riesgo del robo, fraude o mal uso de los recursos.		
A.8.1.1	Roles y responsabilidades	<i>Control</i> Los roles y responsabilidades de seguridad de los empleados, contratistas y usuarios de terceras partes deben definirse y documentarse de acuerdo con la política de seguridad de la información de la organización.
A.8.1.2	Selección	<i>Control</i> La verificación de los antecedentes sobre todos los candidatos para empleados, contratistas, y usuarios de terceras partes deben llevarse a cabo de acuerdo con las leyes, reglamentaciones y ética pertinentes, y proporcionales a los requisitos del negocio, a la clasificación de la información a ser accesada, y los riesgos percibidos.
A.8.1.3	Términos y condiciones de empleo	<i>Control</i> Como parte de su obligación contractual, los empleados contratistas y usuarios de terceras partes deben acordar y firmar los términos y condiciones de su contrato de trabajo, que debe declarar sus responsabilidades por la seguridad de la información de la organización.
A.8.2 Durante el empleo		
<i>Objetivo:</i> Asegurar que todos los empleados, contratistas y usuarios de terceras partes son conscientes de las amenazas y aspectos relacionados con la seguridad de la información, sus responsabilidades y obligaciones, y que estén equipados para respaldar la política de seguridad de la organización en el curso normal de su trabajo, y reducir el riesgo de error humano.		
A.8.2.1	Responsabilidades de la dirección	<i>Control</i> La dirección debe requerir que los empleados, contratistas y usuarios de terceras partes apliquen la seguridad de acuerdo con las políticas y procedimientos establecidos de la organización.
A.8.2.2	Toma de conciencia, educación y formación en la seguridad de la información	<i>Control</i> Todos los empleados de la organización y, cuando sea pertinente, los contratistas y usuarios de terceras partes deben recibir la formación en toma de conciencia y las actualizaciones regulares apropiadas en las políticas y procedimientos de la organización, como sea pertinente para su función de trabajo.

4 Explicación: La palabra "empleo" significa cubrir todas las diferentes situaciones siguientes: empleo de personas (temporal o contratada), la asignación de roles de trabajo, cambio de roles de trabajo, asignación de contratos, y la terminación de cualquiera de estos arreglos.

A.8.2.3	Proceso disciplinario	Control Debe haber un proceso disciplinario formal para los empleados quienes cometan un incumplimiento de seguridad.
A.8.3 Terminación o cambio de empleo		
Objetivo: Asegurar que los empleados, contratistas y usuarios de terceras partes se retiran de una organización o cambian el empleo de una manera ordenada.		
A.8.3.1	Responsabilidades de la terminación	Control Deben definirse y asignarse claramente las responsabilidades para llevar a cabo la terminación o cambio de empleo.
A.8.3.2	Devolución de los activos	Control Todos los empleados, contratistas y usuarios de terceras partes deben devolver todos los activos de la organización en su posesión, una vez terminado su empleo, contrato o acuerdo.
A.8.3.3	Retiro de los derechos de acceso	Control Los derechos de acceso de todos los empleados, contratistas y usuarios de terceras partes a la información y recursos para el procesamiento de la información deben retirarse una vez terminado su empleo, contrato o acuerdo, o una vez ajustado el cambio.
A.9 Seguridad física y ambiental		
A.9.1 Áreas seguras		
Objetivo: Prevenir el acceso físico no autorizado, daño e interferencia a las instalaciones e información de la organización.		
A.9.1.1	Perímetro de seguridad física	Control Los perímetros de seguridad (barreras tales como paredes, puertas de entrada controladas por tarjeta, o puesto de recepción manual) deben utilizarse para proteger las áreas que contienen la información, y las instalaciones de procesamiento de la información.
A.9.1.2	Controles físicos de entrada	Control Las áreas de seguridad deben estar protegidas por controles de entrada apropiados que aseguren el permiso de acceso sólo al personal autorizado.
A.9.1.3	Seguridad de oficinas, habitaciones e instalaciones	Control Debe diseñarse y aplicarse la seguridad física para oficinas, habitaciones, e instalaciones.
A.9.1.4	Protección contra las amenazas externas y ambientales	Control Debe diseñarse y aplicarse la protección física contra el daño por fuego, inundación, sismo, explosión, disturbios, y las otras formas de desastre natural o hecho por el hombre.
A.9.1.5	Trabajo en áreas seguras	Control Deben diseñarse y aplicarse la protección física y las directrices para trabajar en áreas seguras.
A.9.1.6	Áreas de acceso al público, entrega y carga	Control Los puntos acceso, como las áreas de entrega y carga y otras donde las personas no autorizadas pueden entrar en las instalaciones, deben controlarse y, si es posible, aislarse de instalaciones de procesamiento de la información para evitar el acceso no autorizado.

A.9.2 Seguridad de los equipos

Objetivo: Prevenir pérdidas, daños, robo o comprometer los activos e interrupción de las actividades de la organización.

A.9.2.1	Ubicación y protección del equipo	Control El equipo debe ubicarse o protegerse para reducir los riesgos de amenazas y peligros ambientales, y oportunidades para el acceso no autorizado.
A.9.2.2	Servicio de apoyo	Control El equipo debe protegerse contra fallas de energía y otras interrupciones eléctricas causadas por fallas en los servicios de apoyo.
A.9.2.3	Seguridad del cableado	Control El cableado de energía eléctrica y de comunicaciones, que transporta datos o brinda apoyo a los servicios de información, debe protegerse contra interceptación o daño.
A.9.2.4	Mantenimiento de equipos	Control Los equipos deben mantenerse adecuadamente para asegurar su continua disponibilidad e integridad.
A.9.2.5	Seguridad de equipos fuera de las instalaciones de la organización	Control Debe aplicarse la seguridad a los equipos exteriores teniendo en cuenta los diferentes riesgos de trabajar fuera de las instalaciones de la organización.
A.9.2.6	Seguridad en la reutilización o eliminación de equipos	Control Todos los elementos del equipo que contengan dispositivos de almacenamiento de datos deben controlarse, para asegurar que cualquier dato sensible y software bajo licencia ha sido removido o tachado antes de su disposición.
A.9.2.7	Retiro de la propiedad	Control No deben sacarse de las instalaciones, sin autorización, los equipos, la información o el software.

A.10 Gestión de comunicaciones y operaciones**A.10.1 Procedimientos y responsabilidades de operación**

Objetivo: Asegurar la operación correcta y segura de los recursos de tratamiento de información.

A.10.1.1	Documentación de procedimientos operativos	Control Los procedimientos operativos deben documentarse, mantenerse, y estar disponibles a todos los usuarios que los necesitan.
A.10.1.2	Gestión de cambio	Control Deben controlarse los cambios para los recursos y sistemas de procesamiento de la información.
A.10.1.3	Segregación de tareas	Control Las tareas o áreas de responsabilidad deben segregarse para reducir las oportunidades de modificación no autorizada o mal uso de los activos de la organización.
A.10.1.4	Separación de los recursos para el desarrollo, prueba/ensayo y operación.	Control Deben separarse los recursos para el desarrollo, prueba/ensayo y operación para reducir los riesgos del acceso no autorizado o cambios al sistema operativo.

A.10.2 Gestión de entrega de servicio de tercera parte		
<i>Objetivo:</i> implementar y mantener el nivel apropiado de seguridad de la información y la entrega del servicio en línea con los acuerdos de entrega de servicio de tercera parte.		
A.10.2.1	Entrega del servicio	<i>Control</i> Debe asegurarse que los controles de seguridad, las definiciones del servicio y niveles de entrega incluidos en el acuerdo de entrega de servicio de tercera parte son implementados, operados, y mantenidos por la tercera parte.
A.10.2.2	Seguimiento y revisión de los servicios de tercera parte	<i>Control</i> Los servicios, informes y registros suministrados por la tercera parte deben ser seguidos y revisados regularmente, y deben ser llevadas a cabo auditorías regularmente.
A.10.2.3	Gestión de cambios para los servicios de tercera parte	<i>Control</i> Los cambios para el suministro de servicios, incluyendo el mantenimiento y mejora de las políticas, procedimientos y controles de seguridad de información existentes, deben gestionarse, tomando en cuenta la criticidad del sistemas del negocio y los procesos involucrados y la revaluación de los riesgos.
A.10.3 Planificación y aceptación del sistema		
<i>Objetivo:</i> Minimizar el riesgo de fallas de los sistemas.		
A.10.3.1	Gestión de la capacidad	<i>Control</i> Deben realizarse seguimiento, ajustes, y proyecciones de los requisitos de la capacidad futura de la utilización de los recursos, para asegurar el desempeño del sistema requerido
A.10.3.2	Aceptación del sistema	<i>Control</i> Deben establecerse los criterios de aceptación para los nuevos sistemas de información y versiones nuevas o mejoradas y deben desarrollarse pruebas adecuadas de los sistemas durante el desarrollo y antes de la aceptación.
A.10.4 Protección contra código malicioso y movable		
<i>Objetivo:</i> Proteger la integridad del software y de la información.		
A.10.4.1	Controles contra código malicioso	<i>Control</i> Deben implantarse los controles de detección, prevención y recuperación para la protección contra código malicioso, y procedimientos adecuados de toma de conciencia de los usuarios.
A.10.4.2	Control contra código movable	<i>Control</i> Donde la utilización de código movable está autorizada, la configuración debe asegurar que el código movable autorizado opera de acuerdo con una política de seguridad claramente definida, y debe prevenirse el ejecutar el código movable no autorizado.
A.10.5 Copia de seguridad		
<i>Objetivo:</i> Mantener la integridad y la disponibilidad de la información y los recursos de procesamiento de la información.		
A.10.5.1	Copia de seguridad de la información	<i>Control</i> Las copias de seguridad de la información y software deben ser tomadas y probadas con regularidad de acuerdo con la política de copia de seguridad acordada.

A.10.6 Gestión de seguridad de la red		
<i>Objetivo:</i> Asegurar la protección de la información en las redes y la protección de su infraestructura de soporte.		
A.10.6.1	Controles de red	<i>Control</i> Las redes deben gestionarse y controlarse adecuadamente, a fin de estar protegidas de las amenazas, y mantener la seguridad para los sistemas y aplicaciones que utiliza la red, incluyendo la información en tránsito.
A.10.6.2	Seguridad de servicios de red	<i>Control</i> Las características de seguridad, los niveles del servicio, y los requisitos de gestión de todos los servicios en red deben identificarse e incluirse en cualquier acordado de servicio de red, ya sea que estos servicios sean proporcionados en la empresa o subcontratados.
A.10.7 Manejo de medios de información		
<i>Objetivo:</i> Prevenir la divulgación, modificación, eliminación o destrucción no autorizada de los activos, e interrupción de las actividades del negocio.		
A.10.7.1	Gestión de medios removibles	<i>Control</i> Deben existir procedimientos para la gestión de medios removibles.
A.10.7.2	Disposición de medios	<i>Control</i> Cuando ya no son requeridos, los medios de información deben eliminarse de forma segura y sin peligro, utilizando procedimientos formales.
A.10.7.3	Procedimientos de manejo de la información	<i>Control</i> Se deben establecer procedimientos para el manejo y almacenamiento de la información para protegerla contra su uso inadecuado o divulgación no autorizada.
A.10.7.4	Seguridad de la documentación de sistemas	<i>Control</i> La documentación de sistema debería protegerse contra el acceso no autorizado.
A.10.8 Intercambio de información		
<i>Objetivo:</i> Mantener la seguridad de la información y el software intercambiado dentro de una organización y con cualquier entidad externa.		
A.10.8.1	Políticas y procedimientos de intercambio de información	<i>Control</i> Deben establecerse políticas, procedimientos de intercambio formales, y controles para proteger el intercambio de información a través de la utilización de toda clase de recursos de comunicación.
A.10.8.2	Acuerdos de intercambio	<i>Control</i> Deben establecerse acuerdos, para el intercambio de información y software entre la organización y partes externas.
A.10.8.3	Medios de información físicos en tránsito	<i>Control</i> Los medios que contienen la información deben protegerse contra el acceso no autorizado, mal uso o corrupción durante el transporte más allá de los límites físicos de una organización.
A.10.8.4	Mensaje electrónico	<i>Control</i> Debe estar apropiadamente protegida la información involucrada en el mensaje electrónico.
A.10.8.5	Sistemas de información del negocio	<i>Control</i> Deben desarrollarse e implementarse las políticas y procedimientos para proteger la información asociada con la interconexión de los sistemas de información del negocio.

A.10.9 Servicios de comercio electrónico		
<i>Objetivo:</i> Asegurar la seguridad de servicios de comercio electrónico, y su utilización segura.		
A.10.9.1	Comercio electrónico	<i>Control</i> La información involucrada en la transferencia de comercio electrónico en redes públicas debe protegerse de la actividad fraudulenta, litigios contractuales, y la divulgación o modificación no autorizada.
A.10.9.2	Transacciones en línea	<i>Control</i> La información involucrada en las transacciones en línea debe protegerse para prevenir la transmisión incompleta, pérdida de rutas, alteración de mensaje no autorizado, divulgación no autorizada y duplicación o repetición de mensaje no autorizada.
A.10.9.3	Información disponible públicamente	<i>Control</i> La integridad de la información que está disponible sobre un sistema disponible públicamente debe protegerse para prevenir la modificación no autorizada.
A.10.10 Seguimiento		
<i>Objetivo:</i> Detectar las actividades de procesamiento de la información no autorizadas.		
A.10.10.1	Registro de auditoría	<i>Control</i> Deben producirse y mantenerse los registros de auditorías que registren actividades, excepciones y eventos de seguridad de la información del usuario, durante un período definido para ayudar en futuras investigaciones y seguimiento del control de accesos.
A.10.10.2	Seguimiento de la utilización de los sistemas	<i>Control</i> Deben establecerse los procedimientos para el seguimiento de la utilización de los recursos de procesamiento de la información, y los resultados de las actividades de seguimiento revisadas regularmente.
A.10.10.3	Protección de la información del registro	<i>Control</i> Deben protegerse los recursos de registro e información de registro contra el acceso manipulado y no autorizado.
A.10.10.4	Administrador y operador de registros	<i>Control</i> Deben registrarse las actividades del administrador y el operador del sistema.
A.10.10.5	Registro de fallas	<i>Control</i> Las fallas deben registrarse, analizarse y tomarse las acciones apropiadas.
A.10.10.6	Sincronización de relojes	<i>Control</i> Los relojes de todos los sistemas de procesamiento de la información pertinentes, dentro de una organización o dominio de seguridad, deben sincronizarse con una fuente de tiempo exacta acordada.
A.11 Control de accesos		
A.11.1 Requisitos del negocio para el control de accesos		
<i>Objetivo:</i> Controlar los accesos a la información.		
A.11.1.1	Política de control de accesos	<i>Control</i> Debe establecerse, documentarse y revisarse una política de control de accesos, basada en los requisitos del negocio y de seguridad para el acceso.

A.11.2 Gestión de acceso de usuarios		
<i>Objetivo:</i> Asegurar el acceso del usuario autorizado y prevenir el acceso no autorizado a los sistemas de información.		
A.11.2.1	Registro de usuarios	<i>Control</i> Debe existir un procedimiento formal de registro y desregistro de usuarios para conceder y revocar el acceso a todos los sistemas y servicios de información.
A.11.2.2	Gestión de privilegios	<i>Control</i> Deben restringirse y controlarse la utilización y la asignación de privilegios.
A.11.2.3	Gestión de contraseñas de usuario	<i>Control</i> Debe controlarse la asignación de contraseñas a través de un proceso de gestión formal.
A.11.2.4	Revisión de los derechos de acceso de usuario	<i>Control</i> La dirección debe revisar los derechos de acceso de los usuarios a intervalos regulares, utilizando un proceso formal.
A.11.3 Responsabilidades de usuarios		
<i>Objetivo:</i> Prevenir el acceso de usuarios no autorizados, y comprometer o robar la información y los recursos de procesamiento de información.		
A.11.3.1	Uso de contraseñas	<i>Control</i> Debe requerirse a los usuarios seguir las buenas prácticas de seguridad para la selección y uso de sus contraseñas.
A.11.3.2	Equipo desatendido	<i>Control</i> Los usuarios deben asegurar que los equipos desatendidos estén debidamente protegidos.
A.11.3.3	Políticas de escritorios y pantallas limpias	<i>Control</i> Para los recursos de procesamiento de información, debe adoptarse una política de escritorios limpios de papel y de dispositivos de almacenamiento removibles, y una política de pantallas limpias.
A.11.4 Control de acceso a la red		
<i>Objetivo:</i> Prevenir el acceso no autorizado a los servicios de red.		
A.11.4.1	Política de utilización de los servicios de red	<i>Control</i> Los usuarios sólo deben tener acceso a los servicios que han sido específicamente autorizados a utilizar.
A.11.4.2	Autenticación de usuarios para conexiones externas	<i>Control</i> Deben utilizarse métodos de autenticación apropiados para controlar el acceso por usuarios remotos.
A.11.4.3	Identificación de equipo en redes	<i>Control</i> Debe considerarse la identificación de equipo automático como un medio de autenticar las conexiones de ubicaciones y equipos específicos.
A.11.4.4	Protección del diagnóstico remoto y de la configuración de puerto	<i>Control</i> Debe controlarse el acceso físico y lógico para el diagnóstico y configuración de los puertos.
A.11.4.5	Segregación en redes	<i>Control</i> Deben segregarse los grupos de los servicios de información, los usuarios, y los sistemas de información en las redes.

A.11.4.6	Control de conexión de redes	<i>Control</i> Para redes compartidas, especialmente aquellas que atraviesan las fronteras de la organización, la capacidad de usuarios a conectarse a la red debe restringirse, de acuerdo con la política de control de acceso y los requisitos de las aplicaciones del negocio (véase apartado 11.1).
A.11.4.7	Control de direccionamiento en la red	<i>Control</i> Deben implementarse los controles de direccionamiento a redes, para asegurar que las conexiones entre computadora y los flujos de información no violen la política de control de acceso de las aplicaciones del negocio.
A.11.5 Control de acceso al sistema operativo		
<i>Objetivo:</i> Prevenir el acceso no autorizado a los sistemas operativos.		
A.11.5.1	Procedimientos de conexión segura	<i>Control</i> Debe controlarse el acceso a los sistemas operativos por un procedimiento de conexión segura.
A.11.5.2	Identificación y autenticación del usuario	<i>Control</i> Todos los usuarios deben disponer de un identificador único (ID de usuario) sólo para su uso personal, y debe seleccionarse una técnica de autenticación adecuada, para probar la identidad declarada de un usuario.
A.11.5.3	Sistema de gestión de contraseñas	<i>Control</i> Los sistemas para la gestión de contraseñas deben ser interactivos, y deben asegurar la calidad de las contraseñas.
A.11.5.4	Utilización de las prestaciones del sistema.	<i>Control</i> Debe restringirse y controlarse estrechamente la utilización de programas de servicio que podrían ser capaces de eludir las medidas de control del sistema y de las aplicaciones.
A.11.5.5	Sesión inactiva	<i>Control</i> Las sesiones inactivas deben apagarse después de un período definido de la inactividad.
A.11.5.6	Limitación del tiempo de conexión	<i>Control</i> Las restricciones al horario de conexión deben ser utilizadas para proporcionar seguridad adicional a las aplicaciones de alto riesgo.
A.11.6 Control de acceso a las aplicaciones e información		
<i>Objetivo:</i> Prevenir el acceso no autorizado a la información contenida en los sistemas de aplicación.		
A.11.6.1	Restricción de acceso a la información	<i>Control</i> El acceso a la información y a las funciones del sistema de aplicación por usuarios y personal de soporte debe restringirse, de acuerdo con la política de control de acceso definida.
A.11.6.2	Aislamiento de sistemas sensibles	<i>Control</i> Los sistemas sensibles deben tener un entorno informático dedicado (aislados).
A.11.7 Computación móvil y trabajo a distancia		
<i>Objetivo:</i> Asegurar la seguridad de la información cuando se utilizan recursos de computación móvil y de trabajo a distancia.		
A.11.7.1	Computación móvil y comunicaciones	<i>Control</i> Debe implantarse una política formal, y deben adoptarse las medidas de seguridad apropiadas para proteger contra los riesgos de utilizar recursos de computación móvil y de comunicación.

A.11.7.2	Trabajo a distancia	Control Deben desarrollarse e implementarse políticas, planes operacionales y procedimientos para las actividades de trabajo a distancia.
A.12 Adquisición, desarrollo y mantenimiento de información		
A.12.1 Requisitos de seguridad de los sistemas de información		
<i>Objetivo:</i> Asegurar que la seguridad es una parte integral de los sistemas de información.		
A.12.1.1	Análisis y especificación de los requisitos de seguridad	Control Las declaraciones de los requisitos del negocio para los nuevos sistemas de información o mejoras a los sistemas de información existentes deben especificar los requisitos de control de seguridad.
A.12.2 Procesamiento correcto en las aplicaciones		
<i>Objetivo:</i> Prevenir los errores, pérdida, modificación no autorizada o mal uso de la información en las aplicaciones.		
A.12.2.1	Validación de datos de entrada	Control Deben validarse los datos de entrada a las aplicaciones para asegurarse de que éstos son correctos y apropiados.
A.12.2.2	Control del procesamiento interno	Control Deben incorporarse a las aplicaciones las comprobaciones de validación para detectar cualquier corrupción de la información a través de los errores de procesamiento o actos deliberados.
A.12.2.3	Integridad de mensaje	Control Deben identificarse los requisitos para asegurar la autenticidad y proteger la integridad de mensajes en aplicaciones, e identificarse e implementarse los controles apropiados.
A.12.2.4	Validación de los datos de salida	Control Deben validarse los datos de salida de una aplicación para asegurarse de que el procesamiento de la información almacenada es correcto y apropiado a las circunstancias.
A.12.3 Controles criptográficos		
<i>Objetivo:</i> Proteger la confidencialidad, autenticidad o integridad de la información por los medios criptográficos.		
A.12.3.1	Política sobre la utilización de controles criptográficos	Control Debe desarrollarse e implementarse una política sobre la utilización de controles criptográficos para la protección de la información.
A.12.3.2	Gestión de claves	Control Debe establecerse la gestión de clave para dar apoyo a la utilización por la organización de técnicas criptográficas.
A.12.4 Seguridad de los archivos del sistema		
<i>Objetivo:</i> Asegurar la seguridad de los archivos del sistema		
A.12.4.1	Control del software operativo	Control Deben existir procedimientos establecidos para controlar la instalación del software en sistemas en funcionamiento.
A.12.4.2	Protección de los datos de prueba del sistema	Control Deben seleccionarse cuidadosamente y protegerse y controlarse los datos de prueba.
A.12.4.3	Control de acceso al código fuente del programa	Control Debe restringirse el acceso al código fuente del programa.

A.12.5 Seguridad en los procesos de desarrollo y soporte		
<i>Objetivo:</i> Mantener la seguridad del software y la información del sistema de aplicación.		
A.12.5.1	Procedimientos de control de cambios	<i>Control</i> La implementación de los cambios debe ser controlada por la utilización de procedimientos formales de control de cambios.
A.12.5.2	Revisión técnica de aplicaciones después de los cambios de sistema operativo	<i>Control</i> Cuando los sistemas operativos son cambiados, deben revisarse y probarse las aplicaciones críticas del negocio para asegurarse de que no hay impacto adverso sobre las operaciones, o la seguridad de la organización.
A.12.5.3	Restricciones en los cambios a los paquetes de software.	<i>Control</i> Las modificaciones a paquetes de software deben ser desalentadas, limitadas a los cambios necesarios, y todo cambio debe controlarse estrictamente.
A.12.5.4	Fuga de información	<i>Control</i> Deben prevenirse las oportunidades de fuga de información.
A.12.5.5	Desarrollo de software contratado externamente	<i>Control</i> La organización debe supervisar y realizar seguimiento al desarrollo de software contratado externamente.
A.12.6 Gestión de vulnerabilidad técnica		
<i>Objetivo:</i> Reducir los riesgos que resultan de la exposición de las vulnerabilidades técnicas publicadas.		
A.12.6.1	Control de las vulnerabilidades técnicas	<i>Control</i> Debe obtenerse la información oportuna sobre las vulnerabilidades técnicas del sistema de información que está siendo utilizado, evaluarse la exposición de la organización a tales vulnerabilidades, y tomarse las medidas apropiadas para tratar el riesgo asociado.
A.13 Gestión de incidente de seguridad de la información		
A.13.1 Reportar los eventos y debilidades de seguridad de la información		
<i>Objetivo:</i> Asegurar que los eventos y debilidades de seguridad de la información asociadas con los sistemas de información sean comunicados de una manera tal que permita que la acción correctiva sea tomada oportunamente.		
A.13.1.1	Reporte de los eventos de seguridad de información	<i>Control</i> Deben reportarse los eventos de seguridad de la información a través de los canales de gestión apropiados tan rápidamente como sea posible.
A.13.1.2	Reporte de debilidades de seguridad	<i>Control</i> Debe requerirse a todos los empleados, contratistas y usuarios de terceras partes de los sistemas y servicios de información, detectar e informar cualquier debilidad en la seguridad de los sistemas o servicios, que haya sido observada o sospechada.
A.13.2 Gestión de los incidentes y mejoras de seguridad de la información		
<i>Objetivo:</i> Asegurar que un enfoque coherente y eficaz es aplicado a la gestión de los incidentes de seguridad de la información.		
A.13.2.1	Responsabilidades y procedimientos	<i>Control</i> Deben establecerse las responsabilidades y procedimientos de gestión para asegurar una respuesta rápida, eficaz y ordenada a los incidentes de seguridad de información.

A.13.2.2	Aprendizaje de los incidentes de seguridad de la información	<i>Control</i> Deben establecerse mecanismos que permitan cuantificar y realizar el seguimiento de los tipos, volúmenes y costos de los incidentes de seguridad de información.
A.13.2.3	Recolección de evidencias	<i>Control</i> Cuando una acción de seguimiento contra una persona u organización, después de un incidente de seguridad de la información que involucra acciones legales (civiles o criminales), deben recolectarse, conservarse y presentarse evidencias conforme a las reglas establecidas por la legislación aplicable, o por el tribunal que sigue el caso.

A.14 Gestión de continuidad del negocio

A.14.1 Aspectos de seguridad de la información de la gestión de continuidad del negocio

Objetivo: Contrarrestar las interrupciones de las actividades del negocio y proteger los procesos críticos del negocio de los efectos de fallas significativas o desastres de los sistemas de información, y asegurar su reanudación oportuna.

A.14.1.1	Inclusión de la seguridad de la información en el proceso de gestión de la continuidad del negocio	<i>Control</i> Un proceso dirigido debe ser desarrollado y mantenido para la continuidad del negocio, a través de la organización que trate los requisitos de seguridad de la información necesarios para la continuidad del negocio de la organización.
A.14.1.2	Continuidad del negocio y evaluación del riesgo	<i>Control</i> Los eventos que pueden causar interrupciones a los procesos del negocio deben identificarse, al mismo tiempo que la probabilidad e impacto de tales interrupciones y sus consecuencias para la seguridad de la información.
A.14.1.3	Desarrollar e implementar planes de continuidad que incluyan la seguridad de la información	<i>Control</i> Deben desarrollarse e implementarse planes para mantener y recuperar las operaciones y asegurar la disponibilidad de la información al nivel requerido y en los plazos requeridos, tras la interrupción o la falla en los procesos críticos del negocio.
A.14.1.4	Marco de planificación para la continuidad del negocio	<i>Control</i> Se debe mantener un esquema único de planes de continuidad del negocio, para asegurar que dichos planes son coherentes, para tratar coherentemente los requisitos de seguridad de la información, y para identificar las prioridades de prueba y mantenimiento.
A.14.1.5	Prueba, mantenimiento y revaluación de los planes de continuidad del negocio	<i>Control</i> Deben probarse y actualizar con regularidad los planes de continuidad del negocio, para asegurarse de su actualización y eficacia.

A.15 Cumplimiento

A.15.1 Cumplimiento de requisitos legales

Objetivo: Evitar incumplimientos de cualquier ley, estatuto, obligación, reglamentarios o contractuales, y de cualquier requisito de seguridad.

A.15.1.1	Identificación de la legislación aplicable	<i>Control</i> Deben definirse, documentarse y mantenerse actualizados todos los requisitos legales, reglamentarios y contractuales pertinentes y el enfoque de la organización que cumplan estos requisitos para cada sistema de información y de la organización.
A.15.1.2	Derechos de propiedad intelectual (DPI)	<i>Control</i> Deben implementarse los procedimientos apropiados para asegurar el cumplimiento de los requisitos legales, reglamentarios y contractuales sobre el uso del material protegido por derechos de propiedad intelectual, y sobre el uso de productos de software reservados.

A.15.1.3	Protección de los registros de la organización	Control Deben protegerse los registros importantes contra pérdida, destrucción y falsificación, de acuerdo con los requisitos legales, estatutarios, reglamentarios y contractuales y del negocio.
A.15.1.4	Protección de datos y de la privacidad de la información personal	Control Deben asegurarse la protección de datos y la privacidad como sea requerido en la legislación, las reglamentaciones pertinentes, y, si es aplicable, en las cláusulas contractuales.
A.15.1.5	Prevención del mal uso de los recursos de procesamiento de la información	Control Debe disuadirse a los usuarios de utilizar los recursos de procesamiento de la información para propósitos no autorizados.
A.15.1.6	Regulación de controles criptográficos	Control Deben utilizarse los controles criptográficos en cumplimiento con todos los acuerdos, leyes, y regulaciones pertinentes.
A.15.2 Cumplimiento con las políticas y normas de seguridad y el cumplimiento técnico		
<i>Objetivo:</i> Asegurar el cumplimiento de los sistemas con las políticas y normas de seguridad de la organización.		
A.15.2.1	Cumplimiento con las políticas y normas de seguridad	Control Los gerentes deben asegurar que todos los procedimientos de seguridad dentro de su área de responsabilidad son llevados a cabo correctamente, para alcanzar el cumplimiento con las normas y políticas de seguridad.
A.15.2.2	Comprobación del cumplimiento técnico	Control Debe comprobarse regularmente la compatibilidad de los sistemas de información con las normas de implementación de seguridad.
A.15.3 Consideraciones de auditoría de los sistemas de información		
<i>Objetivo:</i> Maximizar la efectividad y minimizar las interferencias en el proceso de auditoría del sistema de la información.		
A.15.3.1	Control de auditoría de los sistemas de información	Control Deben planificarse cuidadosamente y acordarse los requisitos y actividades de auditoría que involucren comprobaciones en los sistemas operativos, para minimizar el riesgo de interrupción de los procesos de negocio.
A.15.3.2	Protección de las herramientas de auditoría de los sistemas de información	Control Debe protegerse el acceso a las herramientas de auditoría del sistema de la información para prevenir cualquier posible mal uso o compromiso.